

Bienvenidos



Ciberseguridad en la protección de red

Seguridad en dispositivos y administración

Javier Benvenuto Servat

jbenvenuto@esan.edu.pe

Agenda

- Acceso seguro a dispositivos.
- Asignación de roles administrativos.
- Autenticación, Autorización, Accounting (AAA).

Acceso seguro a dispositivos



- Todos los dispositivos que componen una red, se deben asegurar, no dejarlos con configuración por default.
- Se les debe aplicar un “hardening” ya sea aplicando una LBS, Línea Base de Seguridad, un checklist “hecho en casa” o adoptando uno de CIS control.

Acceso seguro a dispositivos

- Dicho “hardening” debe incluir como minimo:
 - Cambiar el usuario y contraseña de admin.
 - Se debe de limitar su acceso a la consola administrativa:
 - Físico
 - Remoto
 - CLI
 - Web (https no http)
 - Putty (SSH no Telnet)
 - SFTP no FTP
 - SNMP v3
- La red o VLAN de gestión debe ser distinta a la VLAN de servicios o da data.
- La VLAN de gestión debe ser accesible solo desde ciertos puntos de la red interna y con casos excepcionales desde Internet, con los mecanismos adecuados: VPN,ZTNA, MFA.



Acceso seguro a dispositivos



Asignación de Roles Administrativos

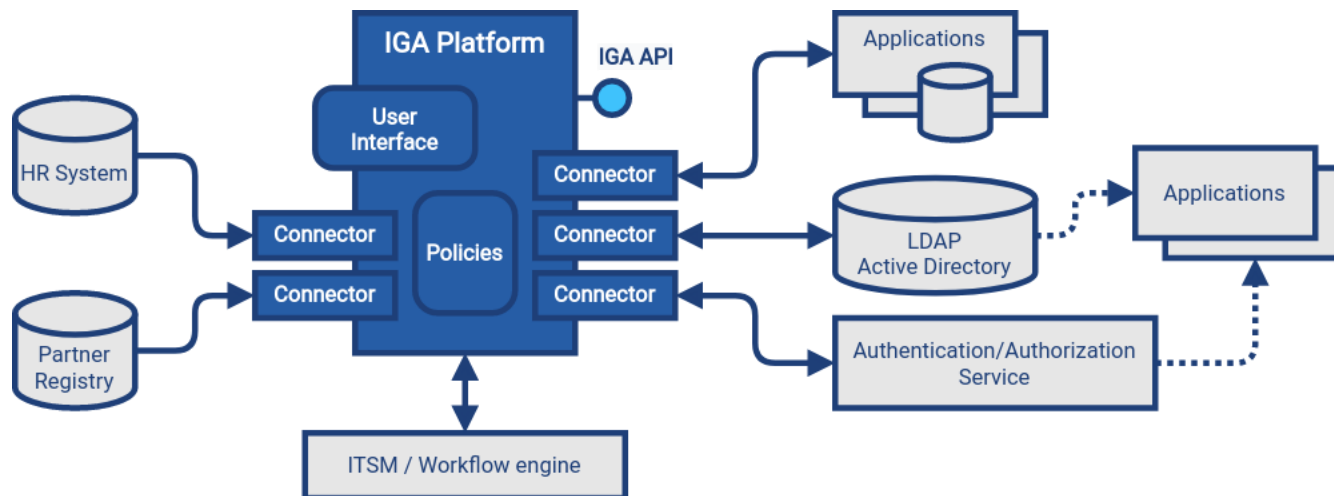
- En la medida de lo posible se debe usar **RBAC**, Rol Based Access Control



- Definir roles de usuarios con acceso sólo de lectura: Pej para Helpdesk, para operadores de NOC.
- Los roles administrativos deberían de ser segmentados. Pej por tipo de Red: LAN, MAN, WAN o por tipo de ubicación: Pej Data Center, Campus, Branch

Asignación de Roles Administrativos

- Dichos roles deben estar asociados a una matriz de roles, con un owner definido por área, debe existir un gobierno que incluya altas, modificaciones y bajas.
- Utilizar un LDAP. **L**ightweight **D**irectory **A**ccess **P**rotocol donde se puedan crear grupos para asociarlo a los roles.
- Se debe de contar con una solución de **IGA**. **I**ntity **G**overnance **A**dministrartion o **IDM** **I**D **M**anagement



Autenticación, Autorización, Accounting (AAA)

- Se debe implementar el proceso AAA en todos los equipos de red:
- **Autenticación** (¿Quién eres?):
Es el proceso de verificar la identidad del usuario o dispositivo que intenta ingresar a la red. Se logra mediante la presentación de credenciales como contraseñas, pines, tokens biométricos o certificados digitales.
- **Autorización** (¿Qué puedes hacer?):
Determina a qué recursos, servicios o privilegios tiene derecho el usuario una vez que su identidad ha sido autenticada. Define los niveles de acceso (lectura, escritura, ejecución) para evitar que usuarios no autorizados alteren datos sensibles.
- **Accounting** (¿Qué hiciste?):
Registra y audita todas las actividades del usuario durante su sesión. Esto incluye la hora de inicio y fin de sesión, los recursos a los que accedió y el volumen de datos consumidos. Se utiliza para la monitorización, auditoría de seguridad y facturación.

Autenticación, Autorización, Accounting (AAA)

- Los protocolos para implementar AAA son Radius y TACACS+

RADIUS vs TACACS+: What To Choose For Your Enterprise?



RADIUS



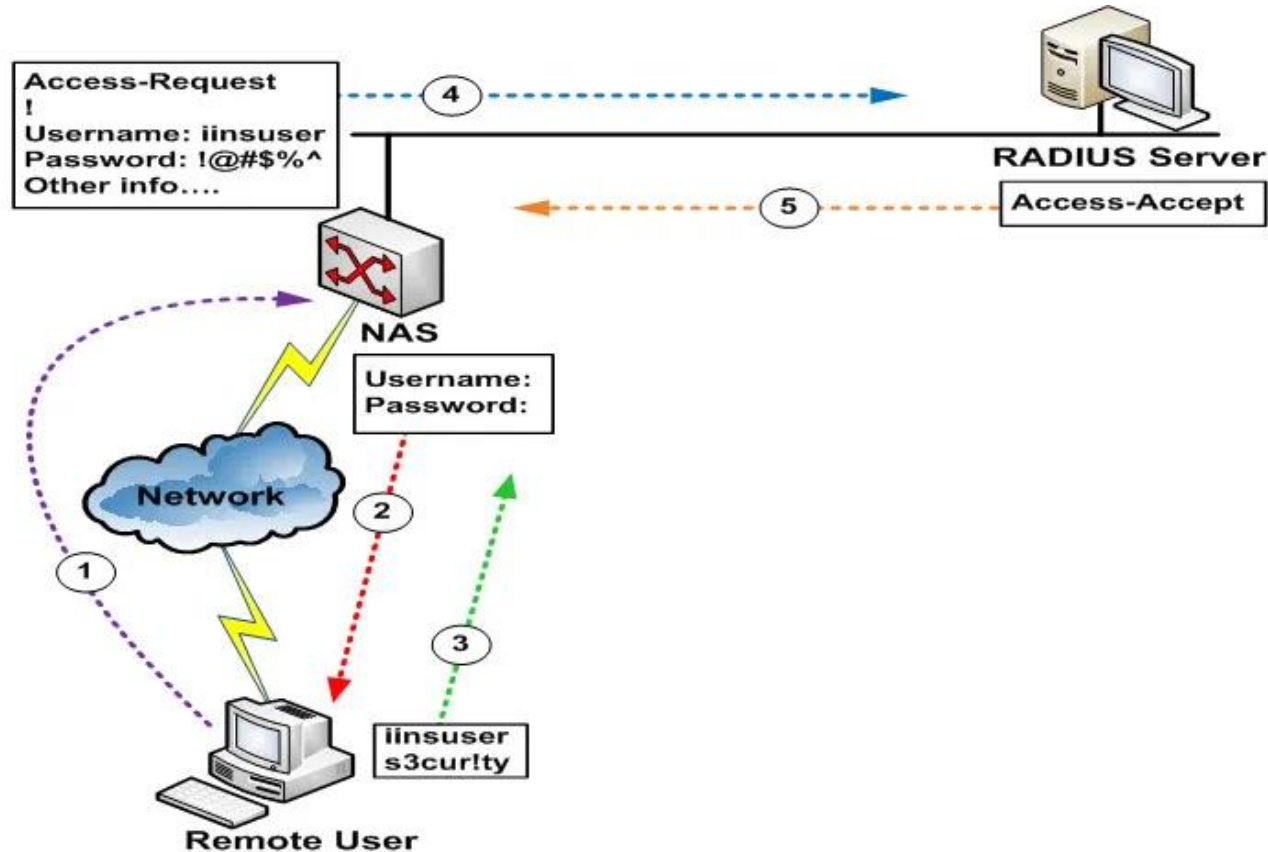
TACACS+

Autenticación, Autorización, Accounting (AAA)

- Diferencias:

Feature	TACACS+	RADIUS
Authentication and Authorization	Separated	Combined
Accounting	Separated	Separated
Protocol	Cisco proprietary	Open standard
Transmission Protocol	TCP	UDP
Encryption	All AAA packets are encrypted	Only passwords are encrypted
Port Number	49	1812 (authentication and authorization), 1813 (accounting)
Granular Control over Authorization	Yes, can specify the particular command for authorization	No external authorization of commands is supported
Multiprotocol Support	Yes, offers multiprotocol support	No multiprotocol support
Device Administration or Network Access	Device administration	Network access

Autenticación, Autorización, Accounting (AAA)



Conclusiones

Join at **www.kahoot.it**
or with the **Kahoot!** app



Wrap up!